

Fuzzing Lecture Material

Course: *Introduction to Vulnerability Research*

Author name: *Dr. Bernard Lampe*

Due date: *October 22th, 2019*

Introduction

1. Most important question is "When is using fuzzing appropriate/productive?" and "If fuzzing is appropriate, what type of fuzzing should be used?"
2. Fuzzing has low false positives.
3. Fuzzing has hard time getting past encryption, hashing or compression algorithms. Usually patched out or fuzzing afterwards.
4. Fuzzing results in an unminimized input file that triggers a bug.
5. Must triage outcomes (crashes, hangs) first.
6. Root causing can be hard. Minimize input first by bi-secting input.

Fuzzing Theory

1. Dump fuzzing, black box. No knowledge. Low penetration.
2. Smart fuzzing, white box. Complete re-implement parser. Max penetration.
3. Need a mix of both to hit unknown code path in unexpected ways.
4. Fuzzing can be seen as following compiler design in reverse. (Lexical analysis, syntax analysis, semantic analysis, code generator, optimizer, assembly generation.)
5. Fuzzing as a search general problem.
6. Fuzzing as a maze analogy.
7. Fuzzing as a directed search problem (A^*).

Mutation Fuzzing

1. Binary corruptors.
2. When should a mutation fuzzer be used?

Generative Fuzzing

1. Grammar, generators...
2. When should a generative fuzzer be used?

Instrumentation

1. Instrumentation is about how to detect an software deficiency.
2. Crashes
3. Hangs
4. Difficult to

Corpus Distillation

1. Section 2 stuff...

Generational Fuzzing

1. Section 2 stuff...

Code Coverage

1. Section 2 stuff...

Feedback Fuzzing

1. AFL
2. KASAN

Concolic and Symbolic Fuzzing

1. Stuff about concolic fuzzing...

Scaling Fuzzing Issues

1. Reproducibility/Determinism
- 2.

Fuzzing deeper

1. Theory about skipping outter layers...

Domain specific fuzzing

1. Media fuzzing
2. Javascript (AST Fuzzing)
3. Fuzzing network protocols (http, https, dhcp, ntp, dns, ...)
4. Fuzzing other stuff...

Open Source Fuzzers

1. Radamsa,

Listing 1: Code Example Listing

```
1 int main()  
2 {  
3     printf("hello_worldz\n");  
4     return 0;  
5 }
```

Conclusion

Conclusions here....

References

1. www.fuzzingbook.com